

Executive Summary

System: [Project Name Redacted] **Date:** June 2026

System Purpose

[Project Name Redacted] provides real-time tracking and documentation of high-value assets in transit using AWS GovCloud.

Data and Impact Level

The system handles sensitive data (including PII) at a MEDIUM impact level.

Controls Selected

Five NIST 800-53 controls were selected: access enforcement (AC-3), boundary protection (SC-7), audit logging (AU-2), system monitoring (SI-4), and identification (IA-2). These represent the controls most directly implemented by the project team.

POA&M Status

Five findings were identified: two High, two Medium, and one Low. Remediation plans are in place with target completion dates between August and September 2026.

Recommendation

All other controls are fully implemented. [Project Name Redacted] is recommended for authorization with remediation in progress.

System Description

System Name: [Project Name Redacted]

System Purpose: Provides real-time tracking and documentation of high-value assets in transit using AWS cloud services with redundant storage and automated audit trails.

Data Types Handled: Shipment manifests (sensitive data), customer PII (sensitive data), asset tracking data, real-time location updates, delivery confirmation records.

System Location: AWS GovCloud

Users: Logistics coordinators, security officers, program managers, and external researchers with approved access.

System Boundary: EC2 application servers, RDS database, S3 storage for manifests, VPC with public and private subnets, API Gateway for external partner integration, CloudTrail for audit logging.

Impact Level: Moderate (based on sensitive data types handled)

Control Statements

Project: [Project Name Redacted] **Date:** June 2026 **Purpose:** Document the 5 NIST 800-53 controls selected for the RMF package, with one-sentence statements defining what each control requires.

AC-3 (Access Enforcement)

The system enforces access control policies to ensure that only authorized users and processes can access sensitive resources.

SC-7 (Boundary Protection)

Monitor ingress and egress traffic, as well as internal communications with sensitive network components, and ensure only approved endpoints are used for traffic flow.

AU-2 (Event Logging)

Work with internal teams to create log policies based on events, determine log usage for investigation and review the policies regularly.

SI-4 (System Monitoring)

Using organizational policies, monitor the system and analyze ingress and egress traffic for indicators of compromise and misuse, adjust the system accordingly, seek legal counsel as needed and provide logs to investigative personnel.

IA-2 (Identification & Authentication)

Employees, contractors, and researchers must identify themselves and be authenticated to operate or use services within the system.

Control Selection Rationale

System: [Project Name Redacted] **Date:** June 2026

Selected Controls

AC-3 (Access Enforcement): Setting controls for who has access to the system is a high priority, since [Project Name Redacted] deals with sensitive data.

SC-7 (Boundary Protection): [Project Name Redacted] gives external partners access to its API endpoints, which is the boundary to the rest of the system and must be properly controlled.

AU-2 (Audit Events): Logs are needed to detect and investigate incidents. All compliance frameworks require this.

SI-4 (System Monitoring): Monitoring is standard in compliance. GuardDuty is constantly scanning logs from the perimeter and internally for alerts to send notifications about.

IA-2 (Identification & Authentication): Each user, employee or contractor, must use unique credentials. Shared accounts defeat controls which have been implemented for accountability.

Controls Not Selected

I didn't pick controls like CP-9 (backup) and PE-3 (physical access) because those are either inherited from AWS GovCloud or handled by someone else's policy. The five controls above are the ones the [Project Name Redacted] team actually controls and can be assessed at our system boundary.

Implementation Statements

Project: [Project Name Redacted] **Date:** June 2026 **Purpose:** Document how each NIST 800-53 control is implemented using AWS services.

AC-3 (Access Enforcement)

AWS IAM enforces access control policies for all internal users and processes. IAM roles with least privilege permissions are assigned to EC2 instances and RDS databases. Security groups restrict network access to authorized IP ranges. API Gateway controls external access using API keys, with CloudTrail logging all access attempts for audit.

SC-7 (Boundary Protection)

API Gateway acts as the external boundary, authenticating all incoming requests before they reach the VPC. Inside the VPC, security groups control traffic to EC2 instances and RDS databases. The VPC is segmented into public and private subnets, with application servers in private subnets that have no direct internet access.

AU-2 (Event Logging)

CloudTrail monitors and logs system actions. Logs are ingested and analyzed by CloudWatch. EventBridge uses data from CloudWatch Logs and Insights to send SNS messages for specified activity. S3 buckets are used for long term storage.

SI-4 (System Monitoring)

CloudTrail records all API calls. VPC Flow Logs capture network traffic data. GuardDuty analyzes both to detect indicators of compromise and misuse. CloudWatch monitors GuardDuty findings and triggers SNS alerts for security personnel when threats are detected

IA-2 (Identification & Authentication)

IAM Identity Center centralizes authentication across the organization's multiple accounts and applications. Identity-based policies enforce least privilege for all IAM users and roles. Resource-based policies control access to S3 buckets containing audit logs. MFA is enforced for all privileged accounts via IAM policy. CloudTrail logs all authentication attempts for audit and accountability.

CMMC Applicability

Project: [Project Name Redacted] **Date:** June 2026 **Purpose:** Map selected NIST 800-53 controls to CMMC Level 2 requirements.

AC-3

CMMC Requirement	How This Control Supports It
AC.L2-3.1.1 – Authorized Access Control	Limits information system access to authorized users and processes.
AC.L2-3.1.2 - Transaction and Function Control	Limit information system access to the types of actions that authorized users can perform.

SC-7

CMMC Requirement	How This Control Supports It
SC.L2-3.13.1 – Boundary Protection	Monitor and control ingress and egress traffic, externally and on sensitive internal systems.
SC.L2-3.13.5 – Public Access Separation	Segments the network into public and private subnets.

AU-2

CMMC Requirement	How This Control Supports It
AU.L2-3.3.1 - System Auditing	Create and store logs for monitoring, analysis, and incident reporting.
AU.L2-3.3.2 - User Accountability	Ensure all user actions can be traced back to them for accountability.

SI-4

CMMC Requirement	How This Control Supports It
SI.L2-3.14.6 – System Monitoring	Monitors system activity to detect attacks and indicators of compromise
SI.L2-3.14.7 – Unauthorized Use Detection	Identifies unauthorized use of organizational systems

IA-2

CMMC Requirement	How This Control Supports It
IA.L2-3.5.1 – User Identification	Assigns unique identifiers to all users and processes
IA.L2-3.5.2 – User Authentication	Verifies user identity through passwords, MFA, or other means before granting access